INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

GRC 103 Practical Laboratory

Technical Risk Treatment – Implementing and Validating Security Controls

BY

MIRACLE NWADIARU

C11/26/CGRCE/17587

1. EXECUTIVE SUMMARY

This report presents the findings of a technical risk treatment exercise conducted for Northbridge Services, a fictional organization with an internal document server. The assessment focused on four risks: an unnecessary legacy service, exposed archive content, unauthorized network access and loss of portal content.

The practical exercise used Ubuntu Server 24.04 LTS and Kali Linux virtual machines connected through an isolated host-only network.

The treatments implemented included retiring the legacy service, moving archive files outside the web root, restricting network access using UFW and backing up and restoring the approved portal.

Testing confirmed that the legacy service was disabled, archive requests returned HTTP 403, authorized portal access returned HTTP 200, and an unauthorized source was blocked. The portal was successfully restored, and its SHA-256 checksum verification returned index.html: OK. The observed recovery time was 11 minutes and 37 seconds.

The exercise also evaluated risk transfer, temporary risk acceptance, treatment costs and residual risks. The results demonstrate the importance of implementing controls, validating their effectiveness and maintaining supporting evidence.

2. LAB ENVIRONMENT AND BASELINE ASSESSMENT

2.1 Environment

Component	Configuration
Server	Ubuntu Server 24.04 LTS
Testing machine	Kali Linux
Web server	Nginx

Firewall	UFW
Network	Isolated Host-only

The server hosted a dummy internal portal, an archive directory and a lab-only legacy HTTP service on port 8080. Kali Linux was used to perform network scans and HTTP requests.

2.2 Baseline findings

Initial testing identified the following:

- Ports 80 and 8080 were accessible.
- The root web directory exposed a directory listing.
- The archive directory and its dummy file were accessible.
- The legacy endpoint responded to HTTP requests.

These findings established the need for preventive and corrective controls.

2.3 Inherent risk register

Risk was assessed using a 5 × 5 matrix, with scores calculated as Likelihood × Impact.

Score	**Classification**
1–4	Low
5–9	Medium
10–16	High

17–25	Critical

ID	Identified risk	Likelihood	Impact	Score	Rating
R1	Unnecessary legacy service	4	4	16	High
R2	Exposed archive directory	4	4	16	High
R3	Unauthorized network access	4	4	16	High
R4	Loss of portal content	3	4	12	High

These scores are professional judgments for the exercise, not statistical probabilities or financial values.

3. IMPLEMENTATION AND VALIDATION OF CONTROLS

3.1 R1 – Avoidance of the legacy service

The unnecessary legacy HTTP service running on port 8080 was retired using:

sudo systemctl disable --now grc-legacy

Systemd checks confirmed that the service was disabled and inactive. The immediate post-retirement Nmap scan reported port 8080 as closed. A later scan, after UFW activation, reported it as filtered; a subsequent connection attempt timed out.

The approved web service on port 80 remained available. The simulated change approval was assigned to the IT Operations Manager.

Result: The unnecessary service was retired, reducing the server's attack surface without interrupting the approved portal.

3.2 R2 – Mitigation of archive exposure

The archive directory was moved from the web root to /srv/grc-private/archive, and access permissions were restricted.

The Nginx configuration was updated to disable directory listing and explicitly deny requests to /archive/.

Validation produced the following results:

Test	Actual result
/archive/	HTTP 403
/archive/dummy-records.txt	HTTP 403
/public/	HTTP 200
/	HTTP 403

The approved portal remained accessible. Moving the archive outside the web root and explicitly denying the old URL provided stronger protection than disabling directory listing alone.

Result: Archive access through the tested web paths was successfully restricted.

3.3 R3 – Mitigation of unauthorised network access

UFW was configured with default incoming traffic denied and outgoing traffic allowed. HTTP access on port 80 was permitted only from the authorised Kali IP address, 192.168.56.102. Firewall logging was enabled.

Test	Source	Actual result
Authorised portal request	192.168.56.102	HTTP 200

Blocked-source request	**192.168.56.11**	**Connection timed out; firewall block observed**

The temporary second IP address used for testing was removed afterwards.

Result: The firewall successfully restricted the tested HTTP access to the authorized source. However, firewall restrictions do not provide encryption or application-level authentication.

3.4 R4 – Backup and recovery

A protected backup directory was created at /srv/grc-backups, with permissions restricted to the root user.

The portal's public directory was backed up into public-before-test.tgz. The original file's SHA-256 checksum and recovery start time were recorded. The dummy portal file was then deleted to simulate data loss.

The portal became unavailable, returning HTTP 403 during the test. The backup was restored successfully, and checksum verification returned:

index.html: OK

A final request from Kali returned HTTP 200 and displayed the original portal content.

Recovery measurement	**Result**
Start time	08:56:47 UTC
Finish time	09:08:24 UTC
Observed recovery time	11 minutes 37 seconds

Result: The recovery process successfully restored the portal and verified file integrity. However, the backup was stored on the same server and would not protect against complete host loss or compromise.

4. LOGGING AND MONITORING

Nginx and UFW logs were reviewed to validate access and blocked requests.

The Nginx access log, /var/log/nginx/grc_access.log, recorded the authorised /public/ request with HTTP 200 and the denied /archive/ request with HTTP 403.

UFW logs provided evidence of the blocked-source test. Firewall-blocked requests should not appear as normal Nginx access requests because they do not reach the web application.

The following monitoring plan is recommended:

Activity	**Owner**	**Frequency**	**Escalation threshold**
Portal availability	IT Operations	Daily	Portal does not return HTTP 200
Unexpected open ports	Security Administrator	Weekly	Any unapproved open port
Backup and recovery test	Backup Administrator	Monthly	Backup or restoration failure
Legacy service configuration drift	Security Administrator	Weekly	Port 8080 becomes active

These are proposed ongoing monitoring activities, not continuous monitoring results from the lab.

5. RISK TRANSFER AND ACCEPTANCE

5.1 Risk transfer

A fictional managed-backup service was considered at $120 setup plus $20 monthly, giving a first-year cost of $360.

The proposed provider responsibilities include scheduled backups, backup monitoring, reporting failures and supporting restoration. Northbridge Services would retain responsibility for data ownership, access management, retention requirements, periodic restoration validation and evidence retention.

A service agreement should specify backup frequency, retention, recovery expectations, and restoration testing and escalation procedures.

No actual service was purchased. Engaging a provider would not remove the organisation's accountability for its data.

5.2 Risk acceptance

Temporary use of plain HTTP was considered acceptable only within the isolated lab environment, using dummy data and restricted network access.

Item	Proposed decision
Risk owner	IT Manager
Residual score	6 – Medium
Review date	12 November 2026
Proposed expiry	19 November 2026
Approval	Simulated

Acceptance would be reconsidered if real data were introduced, external connectivity were enabled or the server's use expanded. TLS should be implemented before handling real organizational information or broader network access.

6. COST ANALYSIS AND ALE

6.1 First-year treatment cost comparison

Option	Calculation	First-year cost
A – Hardening	(4 × $25) + $50	$150
B – Managed backup	$120 + (12 × $20)	$360
C – TLS deployment	(3 × $25) + $25	$100

The figures are illustrative assumptions supplied for the exercise.

6.2 Annual Loss Expectancy

Using the assignment's illustrative backup scenario:

- Annual Rate of Occurrence (ARO): 0.2
- Baseline loss per event: $5,000
- Assumed residual loss per event: $1,000

Baseline ALE: 0.2 × $5,000 = $1,000

Residual ALE: 0.2 × $1,000 = $200

Annual risk-reduction benefit: $1,000 − $200 = $800

Option B net first-year benefit: $800 − $360 = $440

These are assumed values, not measured savings. The successful recovery test does not prove the financial estimates. Risk scores must not be converted into monetary values.

A combination of hardening and managed backup is recommended for planning, at an illustrative first-year cost of $510. TLS should also be considered before any wider or real-data deployment.

7. RESIDUAL RISK ASSESSMENT

ID	Risk	Initial score	Residual likelihood	Residual impact	Residual score	Rating
R1	Legacy service	16	1	3	3	Low
R2	Archive exposure	16	1	4	4	Low
R3	Unauthorized network access	16	2	4	8	Medium
R4	Portal content loss	12	2	3	6	Medium

R1 and R2 were reduced to Low following the implemented and tested controls. R3 remains Medium because firewall restrictions do not provide encryption or authentication. R4 remains Medium because the backup is stored on the same host.

The residual ratings are judgment-based assessments informed by the lab evidence.

8. CONCLUSION AND RECOMMENDATIONS

The exercise successfully shows the implementation and validation of four technical risk treatments.

The unnecessary legacy service was retired, archive access was restricted, firewall rules were implemented and tested, and the approved portal was restored successfully from backup.

The results show that technical controls must be supported by testing, evidence, clear ownership and ongoing monitoring.

The following actions are recommended:

1. Keep the legacy service disabled and monitor configuration changes.
2. Maintain archive restrictions and review web-server permissions.
3. Review firewall rules and investigate unexpected open ports.
4. Introduce off-host or managed backups.
5. Conduct regular recovery tests and retain evidence.
6. Implement TLS before using the portal for real data or wider network access.
7. Assign control owners and review residual risks regularly.

The exercise demonstrates that risk treatment is an ongoing process. Successful implementation reduces exposure but does not automatically eliminate all residual risk.